CONNECT YOUR RECEIVER

Signed callbacks for your ERP

Implementation: 18 October 2026 | Merchant API Integration

Automatic connection. Owner-controlled delivery.

Verified merchants generate an API key and connection configuration without a separate admin source approval. Webhooks are optional outbound synchronization to your own HTTPS receiver, with a separate one-time signing secret and receiver ownership verification.

1 / Save

Choose environment, receiver URL and subscribed events.

>

2 / Verify

Validate signature; echo the signed ownership challenge.

>

3 / Enable

Enable delivery, send a synthetic test and inspect the log.

Two different secrets

Secret	Direction / use
NUERS API key	Your backend sends transactions and reads status from NUERS. Only a hash is stored; shown once.
Webhook signing secret	NUERS signs callbacks to your backend. The receiver validates HMAC. Encrypted at rest; shown once; different per endpoint.

Store both only in backend secret management. Never send the API key in callback bodies or URLs. Do not use the NUERS signing secret as a public key. Live and Sandbox use separate receiver configuration and inbox namespaces. API keys cannot manage human dashboard webhook settings.

What this does

Accepted API transactions create immutable metadata events in the same database commit as intake. A separate worker delivers them after commit. The receiver synchronizes known records; it does not create another sale. No callback certifies BIR acceptance. Actual ERP HTTPS acceptance testing remains pending your receiver URL.

DASHBOARD SETUP

Save, verify, enable and test

Review edition | 18 October 2026

1. Sign in as the verified Merchant Admin of an active business and complete login MFA. Open API Integration > Webhooks. Choose Live or Sandbox before adding the endpoint. Integration readers can view metadata; only the owner can change credentials/delivery.
2. Enter a descriptive name and your own HTTPS callback URL on port 443. No IP literals, local/private networks, URL credentials, query strings, fragments, alternate ports, redirects or NUERS self-targets. Use a stable path and a valid TLS certificate. Confirm ownership and select events. Up to five non-revoked endpoints per environment.
3. Save the one-time signing secret in your receiver secret manager. URL and environment are immutable; create a replacement to change them. If a save response is lost, retry the same request ID; it returns no secret again. Rotate if the first secret was not saved.
4. Install your receiver. Click Verify receiver. NUERS queues webhook.endpoint_challenge. Verify the exact-body signature first; reply within the eight-second timeout with 2xx JSON containing nuers_challenge equal to data.challenge. Challenge expires after ten minutes and has one attempt. A successful check leaves the endpoint paused.
5. Click Enable, then Send test. The signed webhook.test event creates no financial record or wallet debit. Check delivered status, HTTP result and signature handling at your backend. Test events and real events use the same signature format, but your business worker must treat webhook.test as no financial action.
6. Monitor dispatcher heartbeat, queued age, failed attempts and dead letters. A heartbeat older than three minutes is displayed as not observed. Use status polling while resolving a delivery outage. Your actual receiver must pass this workflow before Live business processing is enabled.

No callback URL yet?

Continue using the API and status polling. Automatic source configuration does not require a webhook URL or an additional admin source approval. Add your receiver when ready.

EVENT CONTRACT

Metadata and stable identities

Review edition | 18 October 2026

Event	When queued
transaction.accepted	Every newly durably accepted API record.
source.received	An owned-system original was captured.
invoice.issued	A new NUERS original was issued through the API, subject to issuance gates.
payment.recorded	A supplementary payment record was accepted through the API.
webhook.endpoint_challenge	Owner requested a signed receiver ownership check.
webhook.test	Owner requested a synthetic test of an enabled receiver.

```
{
  "id": "<EVENT_UUID>",
  "type": "transaction.accepted",
  "environment": "sandbox",
  "merchant_id": "<EXPECTED_BUSINESS_ID>",
  "subject_id": "<NUERS_INBOX_UUID>",
  "occurred_at": "2026-10-18T20:00:00+08:00",
  "data": {
    "id": "<NUERS_INBOX_UUID>",
    "record_mode": "source_capture",
    "status": "durably_recorded"
  }
}
```

The envelope and event ID never change across retries. More IDs may appear in data: transaction_id, receipt_id and accepted_at. Financial amounts, buyer data, full source JSON and credentials are omitted. Source receipt plus generic acceptance can refer to the same subject: do not book the same sale for each notification.

Read the original using GET /api/integrations/transactions/{data.id} and a transactions:read key for the same environment, business and registered location. Validate IDs and construct the URL under the fixed NUERS origin; never fetch an arbitrary URL supplied by a callback.

SIGNATURE VERIFICATION

Check raw bytes before decoding

Review edition | 18 October 2026

Header	Meaning
X-NUERS-Event	Event UUID; must match signed body id.
X-NUERS-Timestamp	Unix seconds, refreshed for each attempt.
X-NUERS-Signature	v1= plus 64 lowercase hex HMAC-SHA256 digits.
X-NUERS-Environment	live or sandbox; compare with signed body and local configuration.
X-NUERS-Key-Version	Current endpoint signing-secret version; compare with local configuration.

```
message = timestamp + "." + event_id + "." + raw_body
expected = HMAC_SHA256_HEX(signing_secret, message)
accept only constant_time_equal(expected, signature_without_v1)
```

Read the request body once without parsing, pretty-printing, newline conversion or other changes. Require POST application/json at your HTTPS route. Reject missing/malformed/duplicate security headers and bodies above your documented limit (sample: 64 KiB). Reject timestamps more than 300 seconds in either direction; maintain accurate UTC clocks. Never disable certificate validation.

After signature verification, decode JSON and compare body id, environment and merchant_id with headers/local expected values. Environment and key-version headers are not part of the signature input; compare them to signed fields and your configured secret version. Do not trust an unsigned header by itself.

For webhook.endpoint_challenge, echo only the signed data.challenge value in JSON nuers_challenge. For regular events, commit a durable receiver inbox entry unique by environment/event_id before 2xx. Duplicate identical events return 2xx without another business action; conflicting content under an existing ID must fail.

Receiver processing

Acknowledge quickly after durable storage, then perform business work asynchronously. Make downstream work idempotent by subject ID and semantic action, because distinct event types can describe the same accepted transaction. Never rely on delivery order.

PHP RECEIVER CORE

Signed receiver example / 1

Review edition | 18 October 2026

Download /guides/NUERS-Webhook-Receiver.php.txt. PHP 8.2+, PDO SQLite. Adapt the HTTPS route and database integration to your application. Settings come from private configuration, never the request.

```
<?php
/** Example receiver core, PHP 8.2+. Your HTTPS route supplies raw bytes and private
    configuration.
 * Run business work asynchronously from the durable inbox. Never return 2xx before its commit.
 * $settings: secret, key_version, environment, merchant_id. Keep separate per environment.
 * Headers must use the lower-case names below; do not concatenate duplicate security headers.
 */
function nuers_webhook_receive(string $raw, array $headers, array $settings, PDO $db): array
{
    if (strlen($raw) > 65536) return [413, ['error' => 'body_too_large']];
    $id = $headers['x-nuers-event'] ?? '';
    $at = $headers['x-nuers-timestamp'] ?? '';
    $sig = $headers['x-nuers-signature'] ?? '';
    if (!is_string($id) || !preg_match('/^[a-f0-9-]{36}$/D', $id)
        || !is_string($at) || !ctype_digit($at) || strlen($at) > 12
        || abs(time() - (int)$at) > 300
        || !is_string($sig) || !preg_match('/^v1=[a-f0-9]{64}$/D', $sig)
        || ($headers['x-nuers-environment'] ?? '') !== $settings['environment']
        || ($headers['x-nuers-key-version'] ?? '') !== (string)$settings['key_version']) {
        return [401, ['error' => 'invalid_signature_headers']];
    }
    $mac = hash_hmac('sha256', $at.'.'.$id.'.'.$raw, $settings['secret']);
    if (!hash_equals($mac, substr($sig, 3))) return [401, ['error' => 'invalid_signature']];
    try { $event = json_decode($raw, true, 32, JSON_THROW_ON_ERROR); }
    catch (JsonException) { return [400, ['error' => 'invalid_json']]; }
    if (!is_array($event) || ($event['id'] ?? null) !== $id
        || ($event['environment'] ?? null) !== $settings['environment']
        || ($event['merchant_id'] ?? null) !== $settings['merchant_id']) {
        return [400, ['error' => 'unexpected_event_identity']];
    }
    if (($event['type'] ?? '') === 'webhook.endpoint_challenge') {
        $nonce = $event['data']['challenge'] ?? null;
        return is_string($nonce) && strlen($nonce) === 48
            ? [200, ['nuers_challenge' => $nonce]] : [400, ['error' => 'invalid_challenge']];
    }
    if (!in_array($event['type'] ?? '', ['transaction.accepted', 'source.received',
        'invoice.issued', 'payment.recorded', 'webhook.test'], true)) {
        return [400, ['error' => 'unsupported_event']];
    }
    // Example uses SQLite. Set PDO::ATTR_ERRMODE => PDO::ERRMODE_EXCEPTION.
    // Create inbox at deployment: environment TEXT, event_id TEXT, body_hash TEXT,
    // raw_body TEXT, state TEXT, PRIMARY KEY(environment, event_id).
```

The inbox schema and route adapter are explained in the source comments. Create the table at deployment, with a unique environment/event_id primary key. Configure PDO exception mode. This core does not create sales or run your business worker.

PHP RECEIVER CORE

Signed receiver example / 2

Review edition | 18 October 2026

Download /guides/NUERS-Webhook-Receiver.php.txt. PHP 8.2+, PDO SQLite. Adapt the HTTPS route and database integration to your application. Settings come from private configuration, never the request.

```
    $digest = hash('sha256', $raw);
    try {
        $db->beginTransaction();
        $q = $db->prepare('INSERT INTO
    nuers_inbox(environment,event_id,body_hash,raw_body,state)
            VALUES(?,?,?,?,?) ON CONFLICT(environment,event_id) DO NOTHING');
        $q->execute([$settings['environment'], $id, $digest, $raw, 'pending']);
        $q = $db->prepare('SELECT body_hash FROM nuers_inbox WHERE environment=? AND
    event_id=?');
        $q->execute([$settings['environment'], $id]);
        if (!hash_equals((string)$q->fetchColumn(), $digest)) {
            $db->rollBack(); return [409, ['error' => 'event_content_conflict']];
        }
        $db->commit();
        return [200, ['received' => true]];
    } catch (Throwable) {
        if ($db->inTransaction()) $db->rollBack();
        return [503, ['error' => 'durable_storage_unavailable']];
    }
}
// HTTPS route adapter: require this core; read php://input once; map getallheaders()
// keys to lowercase; reject duplicates at the web-server boundary; load settings
// from your backend secret manager; call the function, then http_response_code()
// and json_encode() its returned body with Content-Type: application/json.
// Validate your TLS route and durable worker before enabling Live delivery.
```

The inbox schema and route adapter are explained in the source comments. Create the table at deployment, with a unique environment/event_id primary key. Configure PDO exception mode. This core does not create sales or run your business worker.

RECOVERY AND OPERATIONS

Bounded retries, rotation and observability

Review edition | 18 October 2026

Outcome / action	Behavior
2xx	Success. For ownership checks the JSON challenge echo must also match.
Redirect	No redirect followed; delivery stops with redirect_blocked.
400/401/403/404/405/410/413/422	Permanent receiver rejection; automatic retries stop.
Timeout/5xx/other transient failure	Backoff with jitter, up to 12 attempts within 24 hours. Read logs and reconcile.
Manual retry	At most three cycles/event. Same ID/body; fresh timestamp and current secret version.
Pause / subscription change	Pending incompatible deliveries are cancelled; inspect and manually retry eligible originals after restoration.
Rotate secret	Pauses, changes signing version, invalidates verification; install new secret and reverify.
Revoke / suspended account	Pending dispatch stops; history remains. Already in-flight delivery may arrive.

The worker uses three-minute leases; a crash can repeat a delivery after lease expiry. Global send cap: 600/minute; endpoint cap: 60/minute, plus daily budgets. HTTPS request timeout is eight seconds, response cap 16 KiB. Recheck public DNS on each attempt and pin its vetted address for TLS; private/reserved destinations are blocked. Operations: schedule merchant-webhooks:work --limit=100 --max-seconds=45 every minute under the domain user. Monitor heartbeat, oldest pending age, dead letters and receiver clock drift. Emergency platform switch: NUERS_MERCHANT_WEBHOOK_DELIVERY_ENABLED=false plus config refresh. This does not enable legacy webhook delivery or BIR transport. Use appropriate independent outbound firewall segmentation too.

ACCEPTANCE CHECKLIST

Complete the receiver handover

Review edition | 18 October 2026

Test	Expected result
Correct/modified signature	Valid raw bytes accepted; modified bytes, wrong key and stale timestamp rejected.
Wrong merchant/environment/version	Rejected without storing or processing an unrelated event.
Identical delivery repeated	One inbox row and one downstream action; duplicate gets 2xx.
Same subject, different event types	No duplicate sale or business action.
Receiver storage unavailable	503; sender retains/retries rather than losing the event.
Receiver redirect / private DNS	No follow-up request to unsafe destination; failure visible.
Rotation, pause, resume and revoke	Expected state changes and preserved attempts/IDs.
Outage and out-of-order deliveries	Durable recovery and correct reconciliation; order is not assumed.
Synthetic Sandbox test	No Live record, wallet debit, invoice numbering or BIR transmission.
Actual ERP HTTPS callback	Verify, enable, test and reconcile with your controlled receiver URL.

Do not create billable Live test sales solely to verify connectivity. Maintain sanitized operational evidence: event ID, environment, HTTP status, time/timezone and attempt number. Keep secrets, receiver responses and buyer documents out of logs. Load/availability, backup restores and the external ERP receiver require independent operational acceptance.

Primary engineering references

OWASP SSRF Prevention Cheat Sheet: URL/DNS validation and redirect restrictions. Stripe webhook documentation: raw-body signatures, duplicates and asynchronous receipt. These inform engineering practice; they are not NUERS interoperability certification.